

DOCUMENTO DI PROGETTO: ARCHITETTURA FIREWALL, RETE ED ACCESSI VPN REMOTI CON WIREGUARD E MFA

Infrastruttura di Sicurezza per il CED e le Filiali Periferiche

Destinatari:	Management, Team IT, Amministrazione	Data:	30 Giugno 2026
Stato:	Approvato / Tecnico	Versione:	2.0 (Integrazione NGFW e pfSense)

1. Architettura di Rete e Topologia dei Firewall

L'infrastruttura di sicurezza è distribuita geograficamente per garantire il massimo controllo del traffico e la business continuity sia nella sede centrale che nelle filiali periferiche:

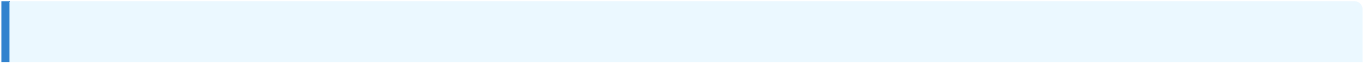
- **Sede Centrale (CED):** Nel nucleo della rete, dove risiedono i server fisici ESXi, i Domain Controller (DC01/DC02) e il File Server (FS01), viene implementato il **Firewall Next-Generation (NGFW) centrale**. Questo apparato si occupa del filtraggio avanzato dei pacchetti, del controllo delle applicazioni, dell'ispezione profonda del traffico (DPI) e della terminazione di tutti i tunnel VPN stabili provenienti dalle filiali e dai client remoti.
- **Filiali e Hotel Vicini (La Meraviglia, L'Incanto):** Presso i siti periferici vengono installati firewall di filiale basati su **pfSense**. Questi apparati gestiscono il routing inter-VLAN locale, la separazione nativa tra reti aziendali e reti ospiti (Wi-Fi Guest, Smart TV) e instaurano i tunnel VPN stabili verso il NGFW del CED centrale.

2. Architettura di Autenticazione (Sinergia Windows Server e Firewall)

L'obiettivo primario è evitare la frammentazione delle utenze. I flussi di autenticazione per l'accesso remoto non vengono configurati localmente sui firewall, ma sono agganciati all'infrastruttura di identità aziendale esistente nel CED.

Componenti del Flusso

1. **Active Directory (DC01 / DC02):** Rappresenta l'archivio unico e centralizzato dei permessi di tutto l'ecosistema (CED e filiali). Nel dominio sono definiti tre gruppi di sicurezza dedicati: VPN_IT, VPN_Direzione, e VPN_Contabilita.
2. **Windows Network Policy Server (NPS01 - Server RADIUS):** Il ruolo NPS sul server NPS01 configura i sistemi di sicurezza affinché agiscano come "RADIUS Client". Quando un utente tenta di negoziare la connessione da remoto, il firewall centrale inoltra la richiesta a NPS01 tramite protocollo RADIUS standard.
3. **Integrazione MFA (Multi-Factor Authentication):** Per rispondere ai requisiti di *Security by Design*, sul server NPS viene implementata l'autenticazione a più fattori. Il server NPS convalida la password su Active Directory e, se corretta, invia una richiesta di approvazione (notifica Push) sullo smartphone dell'utente. Solo dopo l'approvazione del secondo fattore il tunnel permette il passaggio dei dati.



3. Segregazione del Traffico e Profili di Accesso VPN

Una volta superata l'autenticazione MFA, l'utente remoto viene associato a una specifica subnet logica gestita dal firewall. Attraverso regole di filtraggio software (Firewall Rules), il traffico viene rigidamente confinato a seconda del ruolo aziendale.

Profilo Utente	Gruppo di Dominio	Sottorete Assegnata	Risorse Accessibili e Regole di Blocco
IT / Tecnici Esterni	VPN_IT	10.0.90.0/24	Accesso di Gestione Totale: Raggiungimento completo delle interfacce web, SSH e console dei firewall pfSense di filiale, del NGFW centrale, degli switch di rete, degli Hypervisor ESXi 1 e 2, dei sistemi di backup (BK01) e accesso RDP ai Domain Controller. L'accesso ai file aziendali non tecnici rimane protetto dai permessi nativi del file server.
Contabilità	VPN_Contabilita	10.0.91.0/24	Isolamento Fiscale: Accesso consentito esclusivamente al File Server (FS01) limitatamente alle cartelle del reparto amministrativo e al Server Gestionale sulle porte specifiche dell'applicativo. È bloccato qualsiasi tentativo di comunicazione verso stampanti degli hotel, telecamere, o altri apparati di rete del CED.
Direzione	VPN_Direzione	10.0.92.0/24	Accesso Business Ampio: Accesso completo a tutte le condivisioni SMB su FS01, ai gestionali e ai sistemi di reportistica e BI nel CED. Viene esplicitamente bloccato l'accesso ai pannelli di configurazione tecnica (ESXi, configurazione switch, interfacce firewall) per evitare modifiche accidentali.

4. Direttive di Sicurezza sugli Endpoint tramite Group Policy (GPO)

I computer portatili utilizzati da remoto rappresentano il perimetro esterno della rete aziendale. Tramite i Domain Controller del CED (DC01/DC02), vengono applicate GPO stringenti e obbligatorie su tutti i computer Windows aziendali assegnati ai dipendenti.

Configurazioni di Sicurezza Applicate

- **Cifratura Unità BitLocker (Obbligatoria):** Attivazione forzata della crittografia del disco fisso tramite chip TPM. In caso di smarrimento o furto del notebook, i dati aziendali, le sessioni attive e le chiavi crittografiche della VPN WireGuard risultano totalmente inaccessibili ed illeggibili.

- **Privilegi Utente Ridotti (No Admin Locali):** Tutti i profili remoti operano con account utente standard. È inibita l'installazione autonoma di software o driver. Questo impedisce l'esecuzione accidentale di malware, ransomware o strumenti di telecontrollo non autorizzati.
- **Blocco Schermo Forzato per Inattività:** Lo schermo del computer si blocca automaticamente dopo 5 minuti di inattività totale, richiedendo l'inserimento della password di dominio Active Directory. Questa misura protegge l'accesso in contesti domestici, alberghi o spazi pubblici.
- **Inibizione Scrittura su Memorie di Massa USB:** Blocco della scrittura e del trasferimento dati su chiavette USB o hard disk esterni non censiti o non esplicitamente autorizzati. Evita scenari di esfiltrazione fraudolenta o accidentale di dati sensibili.
- **Distribuzione Automatizzata del Client WireGuard:** Il software di connessione viene installato centralmente come servizio di sistema. I file di configurazione (IP e chiavi) vengono inseriti in cartelle protette da liste di controllo di Windows (ACL): l'utente finale può avviare la connessione, ma non può copiare o esportare i parametri della VPN su dispositivi personali.
- **WireGuard Always-On (VPN Sempre Attiva):** Il tunnel è configurato per attivarsi in modo automatico non appena il computer rileva una connessione internet esterna a quella degli hotel. Tutto il traffico del dipendente viene incanalato e ispezionato dal NGFW centrale del CED, estendendo i filtri di sicurezza aziendali (antivirus di rete, web filtering) ovunque si trovi il lavoratore.

5. Monitoraggio e Logging Centralizzato

Ogni tentativo di connessione remota, gli scambi di chiavi WireGuard tra i pfSense e il NGFW e ogni richiesta inoltrata al server RADIUS NPS01 generano un evento tracciabile e centralizzato nel CED. Questo permette un monitoraggio in tempo reale degli accessi, l'individuazione tempestiva di tentativi di intrusione e la revoca immediata delle credenziali e dei certificati VPN in caso di cessazione del rapporto con dipendenti o consulenti IT esterni.